ISO 42001 AI Risk management

Example audit report

March 25 2026

Dr. Sieuwert van Otterloo - CISA CIPP/E

Dr. Pavlo Burda

Public (creative commons with attribution)

available via www.ictinstitute.nl

ICT Institute

Cover: Cash Macanaya on Unsplash

Contents

Audit details 2
Introduction **Error! Bookmark not defined.**
Management summary 3
Audit methodology 3
Audit process 3
Types of findings 3
Audit plan 3
Day 1: [DATE] 3
Day 2: [DATE] 4
Documents 4
Results from review previous audit findings 5
Harmonized Structure (HLS) results 5
ISO42001 Chapter 4 – Context of the organisation 5
ISO42001 Chapter 5 – Leadership 6
ISO42001 Chapter 6 – Planning 6
ISO42001 Chapter 7 – Support 8
ISO42001 Chapter 8 – Operation 8
ISO42001 Chapter 9 – Performance evaluation 9
ISO42001 Chapter 10 – Improvement 10
Annex results 10
A.2 Policies related to AI 10
A.3 Internal organization 11
A.4 Resources for AI systems 11
A.5 Assessing impacts of AI systems 12
A.6 AI system life cycle 13
A.7 Data for AI systems 15
A.8 Information for interested parties of AI systems 16
A.9 Use of AI systems 17
A.10 Third-party and customer relationships 17

About this example report

ISO/IEC 42001 is an organization-level management system standard intended to establish, implement, maintain, and continually improve an AIMS (AI risk Management System) for responsible development/provision/use of AI systems. It uses a Plan-Do-Check-Act approach and helps organizations define responsibilities, assess risks, improve transparency/accountability, manage data quality and system performance, and monitor AI systems throughout their lifecycle.

ISO/IEC 42001 requires companies to have an audit programme resulting in audit reports. This is an example template audit report. The internal audit can be done by an employee not directly involved in the AIMS, or you can ask an independent external expert such as the people from ICT Institute.

This example was created by the people of ICT Institute. You can find the latest version and other templates here: https://ictinstitute.nl/free-templates/

You can use this template/example freely under the Create Commons Attribution license https://creativecommons.org/licenses/by/4.0/

You can do the following with the templates:
Share. You can share the templates and any documents made with these templates freely, with any one that you want to share it with.
Adapt. You can make new documents based on the templates, make changes, add elements or delete elements as much as you want. You can even do this in commercial organisations of for commercial purposes.

If you are a customer, you do not have to mention ICT Institute anywhere. If you are not a customer, you must keep the text "create by the people of ICT Institute" somewhere
Note that the use of these templates is of course at your own risk. Note also that the ISO standards are copyrighted. You must buy the standard from NEN or ISO before using it.

Audit details

Date(s):	[DATE] (day 1) and [DATE] (day 2)
Review location:	[LOCATION]
Audit scope:	The entire AIMS scope for ScaleHigh
Audit goal:	To check whether the AIMS conforms to ScaleHigh's own requirements for its AI management system and the requirements of ISO 42001, and whether the AIMS is effectively implemented and maintained.
Audit criteria:	ISO 42001:2023
Audit team	Auditor
Interviewees:	CEO CISO Developer HR manager IT architect Project manager Sales director

Management summary

This report is the final deliverable of an ISO42001 internal audit, conducted by ICT Institute. The goal of the review was to give the management of the organisation insight into the state of the AI Management System, and fulfil an ISO42001 requirement of performing internal audits. The audit took place in on …

In this audit, no Major Non-Conformities (NC) were found. [AMOUNT] Minor Non-Conformities (MNC) have been found. [AMOUNT] Observations (OBS) were made.
This means that The AIMS of ScaleHigh conforms to its own requirements, the requirements of ISO42001:2023 and is effectively implemented and maintained.

The MNC's are as follows:

- 1.1.1: …
- …

Audit methodology

Audit process

The audit was conducted through online video interviews. In these interviews, the auditor asked the auditees to explain how AIMS elements are implemented. The questions were based on the AIMS requirements and previous audit results. In addition, interviewees were asked to show procedures, contracts, tickets, configuration and other evidence for the implementation of requirements.

Types of findings

The internal audit can return three types of findings:

- **Observation (OBS):** no compliancy issue for ISO42001, but an opportunity for improvement.
- **Minor Non-Conformity (MNC):** a deviation from ISO42001 and/or organisation's procedures that does not affect the overall effectiveness of the AIMS.
- **Non-Conformity (NC):** a deviation from ISO42001 and/or organisation's procedures that affects the overall effectiveness of the AIMS.

Audit plan

Day 1: [DATE]

Time	Topic	Attendees	Norm element
09.30 – 10.00	Audit opening	CEO, CTO/Data Lead	
10.00 – 11.00	Main AIMS structure: context, leadership	CEO, CTO/Data Lead	ISO 42001: 4,5
11.00 – 12.00	Risk management, AI impact assessment	CISO, CTO/Data Lead (CEO optional), Privacy Officer	ISO 42001: 6
12.00 – 13.00	Break		

13.00 – 15.00	Risk management, Execution and Support	CTO/Data Lead (CEO optional), Privacy Officer	ISO 42001: cont. 6, 7, 8
15.00 – 16.00	Goals and evaluation, Continual improvement	CTO/Data Lead (CEO optional)	ISO 42001: 9, 10
16.30 – 16.45	Closing meeting	CEO, CTO/Data Lead	

Day 2: [DATE]

Time	Topic	Attendees	Norm element
09.30 – 10.00	Audit opening	CSO, CEO, CISO	
10.00 – 11.00	Controls for policies related to AI and internal responsibilities	CEO, CTO/Data Lead	A2.2-2.4 (policy), A3.2-3.3 (responsibilities)
11.00 – 12.00	Resources	CTO/Data Lead (CEO optional), HRM	A4.2-4.6 (documentation, tooling and staff)
12.00 – 13.00	Break		
13.00 – 14.00	AI impact assessment controls	CTO/Data Lead, privacy officer	A5.2-5.5 (process, assessment)
14.00 – 15.00	AI system lifecycle controls	CTO/Data Lead, Dev Lead	A6.1.2-6.2.8 (development, deployment and documentation)
15.00 – 16.00	Data for AI system (GDPR, incidents)	CTO/Data Lead	A7.2-7.6 (acquisition, quality and provenance)
15.00 – 16.30	Communication & third-party relationship controls	CTO/Data Lead, CEO/privacy officer	A8 (communication) A9 (use of AI systems) A10 (third-party and customers relationship)
16.30 – 16.45	Closing meeting	CEO, CTO/Data Lead	

Documents

The following documents are part of the core documentation of the AIMS, and should be present during the audit.

Name in this report	Document full name	Version, date
Stakeholders-Context overview	xyz.pdf	[X.X, DD-MM-YYYY]
AI policy (scope)	xyz.pdf	[X.X, DD-MM-YYYY]
Operating procedures-Documentation, Calendar	xyz.pdf	[X.X, DD-MM-YYYY]
Risks register (risk management process)	xyz.pdf	[X.X, DD-MM-YYYY]
Objectives-monitoring-overview	xyz.pdf	[X.X, DD-MM-YYYY]
AI Impact assessment	xyz.pdf	[X.X, DD-MM-YYYY]
Statement of Applicability	xyz.pdf	[X.X, DD-MM-YYYY]
Supplier overview	xyz.pdf	[X.X, DD-MM-YYYY]
Legislation overview	xyz.pdf	[X.X, DD-MM-YYYY]

Management review	xyz.pdf	[X.X, DD-MM-YYYY]
Register of nonconformities-Incidents	xyz.pdf	[X.X, DD-MM-YYYY]
Development guidelines-Training	xyz.pdf	[X.X, DD-MM-YYYY]

Results from review previous audit findings

In the previous external audit, the following nonconformities were found. The resolution will be audited in this audit.

External audit result	Status
1.1.1 …	Resolved
2.2.2 …	Not yet resolved

Harmonized Structure (HLS) results

ISO42001 Chapter 4 – Context of the organisation

	Criterion	Observed in audit	Findings
4.1	**Understanding the organization and its context** ScaleHigh should identify the main internal and external factors that can affect its AIMS together with the overall purpose of the AI systems they use or develop. Climate change is an important factor to consider too.	Which internal and external factors or issues most affect your AIMS and the intended purpose of your AI systems? What is your role for each AI system in scope? Was climate change relevance considered?	
4.2	**Understanding the needs and expectations of interested parties** ScaleHigh must determine stakeholders in its AIMS, their relevant requirements, and address the most important requirements with the AIMS.	Which interested parties/stakeholders are relevant to the AIMS, and what requirements do they have? E.g., end users, customers, regulators, employees Which of these requirements are addressed through the AIMS, and how do you keep this analysis up to date?	
4.3	**Determining the scope of the AI management system** ScaleHigh must define and document the scope of its AI management system. This scope should reflect relevant company factors, stakeholders' requirements, and what the AI system does.	What AI systems, activities, or teams fall within the AIMS scope, and are any excluded? How did you use the issues from 4.1 and stakeholder requirements from 4.2 when defining the scope? Which activities fall within the scope but are outsourced? Are there any activities or employees that fall outside the scope of the ISMS?	
4.4	**AI management system** ScaleHigh must put in place and document an AI management system, keep it running, improve it over time, and ensure that the necessary processes are defined and aligned.	Can you show the documented structure of the AIMS and the key processes and their interactions? How is the AIMS maintained and continually improved in practice?	

ISO42001 Chapter 5 – Leadership

	Criterion	Observed in audit	Findings
5.1	**Leadership and commitment** Management must actively support the AIMS by setting direction, giving resources, embedding it into business processes, and making sure it works and improving.	How does top management communicate the importance of responsible AI and conformity with the AIMS? Can you give an example of how management provides resources or direction for the AIMS? E.g., communication in internal newsletter/intranet, board speech, allocation of time for Ai-related training, dedicated roles-times for AIMS	
5.2	**AI policy** Management must approve an AI policy that fits the organization and the AIMS requirements, while supporting responsible AI objectives. The policy should be easily available for relevant stakeholders.	How was the current AI policy communicated internally and made available to stakeholders? E.g., public on website, upon request, trust centre, internal newsletter How does the policy support AI objectives and continual improvement?	
5.3	**Roles, responsibilities and authorities** Top management at ScaleHigh must assign and communicate clear responsibilities for relevant roles.	Are responsibilities for relevant AI roles clearly assigned and communicated? Who ensures conformity of the AIMS and is responsible for it performance? E.g., a dedicated team, Data Lead, CTO When and how ware the outcomes of th4e AIMS reported to top management? E.g., management review	

ISO42001 Chapter 6 – Planning

	Criterion	Observed in audit	Findings
6.1.1	**Actions to address risks and opportunities - General** When planning its AIMS, the ScaleHigh must identify the main risks and opportunities based on its context, requirements, intended use and application area, define criteria for assessing and treating AI risks, plan and implement appropriate actions, review whether those actions actually work, and keep the related documentation.	How do you identify AI-related risks (and opportunities) based on context, interested parties, intended use, and application domain? (Your risk assessment method) Can you show your risk register? How many risks have you identified? What criteria do you use to distinguish acceptable from non-acceptable AI risks? When was the last risk assessment executed?	
6.1.2	**AI risk assessment** ScaleHigh should create an AI risk assessment process that is aligned with its policy and connected objectives. The assessment must have consistent results, identify and analyse most relevant risks, evaluate how severe and how	Can you show how you determined likelihood and impact on the basis of a risk? Can you explain the AI risk assessment method and show an	

	likely they are. This process should help prioritize them for treatment.	example of recently identified risk? How do you assess consequences for the organization, individuals, and society? How are risks prioritized?	
6.1.3	**AI risk treatment** Based on the previous risk assessment, ScaleHigh must define a process to treat AI risks. This process should select suitable treatment actions, determine the necessary controls, consider the controls below and any additional controls that may be needed, and document the outcome in a statement of applicable controls and an AI risk treatment plan. The plan and any remaining risks must be approved by management, with the related controls and decisions documented and available to relevant parties.	How do you decide on AI risk treatment options and link them to Annex A controls? Can you show the Statement of Applicability? Can you demonstrate the progress and approval of the AI risk treatment plan, including residual risk acceptance? Do you have risks that already have a measure implemented?	
6.1.4	**AI system impact assessment** ScaleHigh must define a process to assess how an AI system could affect individuals, groups, and society. This assessment should consider the system's intended use, possible misuse, and the technical, social, and legal context in which it is deployed. The results must be documented and used as input for the risk assessment, and may also be shared with relevant interested parties where appropriate. If operating with EEA users, a the assessment must be conform to the AI Act article 27.	How you carried out an impact assessment of your AI system? How do you evaluate/measure the impact? Can you show how an AI system impact assessment feeds into the overall risk assessment? Are you a provider or a deployer of the AI system? Is your AI system categorized as an generative AI system? Is your AI system a high-risk system according to the EU AI Act? Does your impact assessment consider the impact on the fundamental rights? Do you communicate the results of your impact assessment to regulators or other parties?	
6.2	**AI objectives and planning to achieve them** ScaleHigh must define AI objectives that objectives align with the AI policy, reflect applicable requirements of the AI system, be monitored and upkept. They should be updated when needed. ScaleHigh must also plan how to achieve them by defining the actions, resources, responsibilities, timing, and evaluation methods.	What are the main AI objectives for your system? E.g., upkeeping the quality data for training, validation and testing, fairness, security, accountability How are they measured and reviewed? Can you show the last objective review and its results? What resources, responsibilities, and timelines have been defined to achieve these AI objectives? Who owns objetives? Does your AI impact assessment provide measures taken to reduce the identified risks/impact?	
6.3	**Planning of changes** Changes and developments to the AIMS must be planned before implemented.	How are changes to the AIMS planned, assessed, and approved before implementation? E.g., Calendar events, ownership	

		Can you show an example of a recent AIMS change and how it was managed?	

ISO42001 Chapter 7 – Support

	Criterion	Observed in audit	Findings
7.1	**Resources** ScaleHigh must provide the resources needed to establish, maintain, and improve the AIMS.	What resources have been made available for establishing, operating, and improving the AIMS? E.g., roles, functions, time, training How do you determine whether additional AI-specific resources or expertise are needed?	
7.2	**Competence** ScaleHigh must ensure that people who can affect AI performance have the right competence through education, training, or experience. Where needed, it must take steps to build that competence and keep evidence of it.	How do you ensure that staff involved in AI activities have the necessary competence? Can you show documented evidence of training, experience, or evaluation of competence for key AI roles?	
7.3	**Awareness** People working under ScaleHigh's control must understand the AI policy, how they contribute to the effectiveness of the AIMS, and the consequences of not following its requirements.	How are employees made aware of the AI policy, their responsibilities, and the consequences of non-conformance (for example in a contract)? Would a new employee know where to find the AI policy and related procedures?	
7.4	**Communication** ScaleHigh must define the internal and external communication needed for the AIMS, including what will be communicated, when, to whom, and how.	What internal and external AIMS communications are planned, and who is responsible for them? Can you demonstrate that the communication activities have actually been carried out?	
7.5.1	**Documented information - General** ScaleHigh's AIMS must include the documented information required by this standard, as well as any additional documentation needed to make the system effective.	Which documents make up the core documented information of the AIMS? How did you decide which additional documented information is necessary for effective AI management?	
7.5.2	**Creating and updating documented information** ScaleHigh must ensure that its documentation and relevant information is in a suitable format, and reviewed and approved before use.	How do you ensure documents have proper identification, versioning, review, and approval? Can you show the version history or approval record of a key AIMS document?	
7.5.3	**Control of documented information** ScaleHigh must control the documented information required for the AIMS so that it is available when needed, protected against misuse or loss, and properly managed throughout its life cycle, including access, storage, versioning, retention, and external documents.	How do you ensure the correct and current version of AIMS documents is available where needed? How are external documents relevant to the AIMS identified, protected, and controlled?	

ISO42001 Chapter 8 – Operation

Criterion	Observed in audit	Findings

8.1	**Operational planning and control** The actions planned for the AIMS by the previously defined criteria should be carried out. It is also mandatory to apply operational controls. To make this approach effective the company should monitoring whether these controls work, as usual, documenting the key activities and managing changes. The same applies to external products, services, and processes.	How do you maintain an overview of all activities to be carried out within the AIMS? E.g., Is there an annual plan? Risk/controls have owners and deadlines? Meeting notes? How do you ensure operations and controls are implemented as planned across the AI lifecycle? E.g., an example of a review of controls in action How are changes to AI systems or external providers controlled and reviewed for adverse effects? E.g., periodic evaluations of control effectives, supplier review	
8.2	**AI risk assessment** ScaleHigh must carry out regular AI risk assessments and be able to demonstrate results of the assessment. This should be done also in case of expected or unexpected adjustments.	When are AI risk assessments repeated, and what triggers an out-of-cycle reassessment? Can you show the documented results of a recent AI risk assessment? E.g., from your AI impact assessment	
8.3	**AI risk treatment** From the identified risks and corresponding treatment plans, ScaleHigh must implement said treatment plan and check whether it works.	Can you show instances of AI risk treatment plans and their implementation? E.g., from your AI impact assessment How do you verify its effectiveness? What happens when a treatment measure is not effective or when new AI risks are identified?	
8.4	**AI system impact assessment** The planned and defined AI impact assessment must be carried out.	When are AI system impact assessments performed or updated, and what changes trigger them? Can you show the documented results of a recent AI system impact assessment?	

ISO42001 Chapter 9 – Performance evaluation

	Criterion	Observed in audit	Findings
9.1	**Monitoring, measurement, analysis and evaluation** The AIMS needs to be monitored regularly, and to achieve this ScaleHigh must decide what to measure in its AIMs, including, how and when. Then, the IS team 9and management) will need to evaluate the monitoring outcomes and keep the result for future references and comparison. This procedure allows to assess the performance and effectiveness of the AIMS.	What AIMS processes, controls, or responsible AI objectives are monitored and measured, and by which methods? When are results analysed, by whom, and how do they inform evaluation of AIMS effectiveness?	

9.2.1	**Internal audit – General** An internal audit must be carried out yearly to independently assure the AIMS correct implementation and effectiveness.	Do you have an (annual) audit plan? How will you discuss and approach the audit results? (9.2.1/.2)	
9.2.2	**Internal audit programme** For the internal audit, there should be a precise schedule of what to audit. Initially the scope can include the whole AIMS, in the following iterations the scope can be risk-based.	How is the internal audit programme defined, including frequency, scope, criteria, and auditor independence? How are previous audit results and process importance considered when planning audits?	
9.3.1	**Management review - General** Management at ScaleHigh must review the AIMS regularly to ensure it work correctly.	When is/was the management review planned?	
9.3.2	**Management review inputs** The management review should evaluate the effectiveness of the AIMS starting from previous review, new factors in the context, any problem with the AIMS including those from audit results. Then, the management should decide what actions to take.	What is the agenda reviewed during management review? E.g., audit results, monitoring results, actions, and changes in context How are opportunities for continual improvement identified during the review?	
9.3.3	**Management review results** Then, the management should decide what actions to take as a function of the review.	What decisions or actions resulted from the latest management review? Are these decisions are tracked and followed up?	

ISO42001 Chapter 10 – Improvement

	Criterion	Observed in audit	Findings
10.1	**Continual improvement** Ideally, ScaleHigh should strive to always improve the AIMS.	Can you give an example of continual improvement actions taken for the AIMS?	
10.2	**Nonconformity and corrective action** Incidents and deviations from a good-working AIMS should be saved as evidence and plans for improvement must be made.	Can you show an example of a nonconformity, its root cause analysis, and the corrective action taken? E.g., Nonconformities register How do you verify that corrective actions were effective and that similar issues do not recur?	

Annex results

A.2 Policies related to AI

This is section is about to ensure management involvement and oversight. The relevant AI Act article is article 17 (quality management system).

	Criterion	Observed in audit	Findings
A.2.2	**AI policy** ScaleHigh must have a policy for developing or using AI systems.	Can you provide the AI policy? How is it aligned with the organization's objectives? Relevant docs: AI policy	
A.2.3	**Alignment with other organizational policies** Other policies might be relevant for AI (e.g., the IS policy). Therefore, these should be considered.	Are there any other affected topic-specific policies? E.g. Information Security policy, privacy policy, quality policy	

A.2.4	**Review of the AI policy** When important changes happen the policy should be updated.	When was the AI policy last approved? By whom? Relevant docs: AI policy, event schedule	

A.3 Internal organization

This section is about ensuring accountability and oversight within the relevant roles and responsibilities. The relevant AI Act articles are article 4 (AI literacy) and article 14 (human oversight).

	Criterion	Observed in audit	Findings
A.3.2	**AI roles and responsibilities** People at ScaleHigh should have assigned AI-related roles and responsibilities.	How are relevant roles and responsibilities defined and documented? (e.g., data leads, privacy officer, CTO) Relevant docs: AI policy/ OP procedures	
A.3.3	**Reporting of concerns** There should be a way to reporting problems and concerns about the AI system.	Have you made available a procedure to report concerns of AI use by employees, users and customers? Relevant documents: Operational procedures	

A.4 Resources for AI systems

This section is about ensuring that the organization accounts for all relevant AI system resources, such as human resources, system resources and governance resources. The relevant AI Act articles are article 10 (data and data governance) and article 11 and Annex IV (technical documentation).

	Criterion	Observed in audit	Findings
A.4.2	**Resource documentation** As many other systems, Ai systems have a life cycle. It should be clear at ScaleHigh what resources are needed for the AI system lifecycle.	What are the resources you provide to manage the AI system lifecycle, from development through deployment and maintenance? E.g., datasets, repositories, pipelines, tooling, documentation, functions/roles, governance and operation resources Relevant docs: Operation procedures-Documentation	
A.4.3	**Data resources** Among the relevant resources, the data resources are very important and should be well documented.	What data resources are used by the AI system, and where are these datasets, data sources, or data inputs documented? Data lineage: How do you keep records of the origin, purpose, ownership, and use of the data resources supporting the AI system? Relevant docs: Operation procedures-Documentation	
A.4.4	**Tooling resources** Similarly, tools used to develop and manage the AI system must be documented.	Which tools, libraries, platforms, or software components are used to build, test, deploy, or monitor the AI system? Can you show where the organization documents these tooling resources (e.g., how their	

		suitability or approval is determined)? Relevant docs: Operation procedures -Documentation (Data governance), , Development guidelines-Training	
A.4.5	**System and computing resources** Resources include the actual system resources in terms of computing needs (e.g., processing time, storage requirements etc.). It must be possible to retrieve such information.	What infrastructure and computing resources are used for the AI system, such as servers, cloud services, GPUs, storage, or network components? Do they include training, inference, and operation? Relevant docs: Operating procedures	
A.4.6	**Human resources** Humans are an essential part of the AI life cycle, therefore the allocated human resources should be known. Among these, it is important to keep the right competences across the fully lifecycle.	Which roles and people are involved in the development, deployment, operation, maintenance, and change management of the AI system, and how are their responsibilities documented? How do you ensure that the staff has the required competences? Relevant docs: job requirements, HRM system	

A.5 Assessing impacts of AI systems

This section is about assessing the impact that an AI system may have on individuals, groups of individuals and society at large. This applies to the whole AI life cycle. The relevant AI Act articles are article 9 (risk management system), 27 (fundamental rights impact assessment), 26 (deployer obligations) and article 17 (documentation).

	Criterion	Observed in audit	Findings
A.5.2	**AI system impact assessment process** ScaleHigh must define a process to assess how the AI system could affect individuals, groups, and society throughout its life cycle. The 'how' to carry out the AI impact assessment. This is particularly relevant for the EU AI Act.	What is your AI impact assessment process? How do you ensure that a fundamental rights impact assessment (FRIA) is kept up to date where relevant? Relevant docs: AI Impact Assessment, Operational procedures	
A.5.3	**Documentation of AI system impact assessments** After an AI impact assessment, it is important to save be able to demonstrate the outcomes.	Can you show the results of past/recent impact assessments? Relevant docs: AI Impact assessment (FRIA)	
A.5.4	**Assessing AI system impact on individuals or groups of individuals** ScaleHigh must carry out an AI impact assessment to people. This is particularly relevant for the EU AI Act.	How do you assess the impact of the AI system on individuals or groups throughout the whole system lifecycle? This includes impacts related to fairness, transparency, privacy,	

		safety, accessibility, financial consequences, and human rights. Relevant docs: AI Impact Assessment (FRIA)	
A.5.5	**Assessing societal impacts of AI systems** The same applies to the society in general.	Are effects on society considered, including effects on, e.g., sustainability (climate), the economy, government, health and safety, and social values? Relevant docs: AI Impact Assessment (FRIA)	

A.6 AI system life cycle

This section is about identifying and achieving the responsible AI objectives throughout the AI system life cycle. The relevant articles for AI Act are art. 11 (technical documentation), art. 12 (record keeping), art. 17 (quality management system), art. 15 (accuracy, robustness and cybersecurity) and art. 19 (retention period).

	Criterion	Observed in audit	Findings
A.6.1.2	**Objectives for responsible development of AI system** To meaningfully develop an AI system that holds responsible Ai values, ScaleHigh must decide relevant objectives for the AIMS to up keep these values.	What are your responsible AI objectives? How do you integrate the objectives into the AI system development lifecycle? E.g., concrete measures in requirements, data, training, testing, and validation Relevant docs: Objectives-Monitoring	
A.6.1.3	**Processes for responsible AI system design and development** The processes for designing the Ai system responsibly should be documented.	How does the organization define and document responsible AI design and development processes? E.g. testing, human oversight, impact assessments, data rules, approvals, change control, and stakeholder engagement Relevant docs: Operating procedures, Development guidelines	
A.6.2.2	**AI system requirements and specification** Along with the documented processes, the relevant requirements should be established as well.	How do you identify AI system requirements, including the system's purpose, goals, and data and training needs, across the lifecycle? E.g. Purpose, goals, business case, data needs, training, requirements, lifecycle, feasibility Relevant docs: project plans	
A.6.2.3	**Documentation of AI system design and development** The processes and requirements should inform the documentation of the AI system design and development.	What are the main requirements and specifications of the AI system? E.g., in terms of acceptable performance (precision, accuracy, recall, etc), type of ML algorithms (supervised/unsupervised), etc.	

		Relevant docs: project plans, Operation procedures-Documentation	
A.6.2.4	**AI system verification and validation** Any AI system must be validated before deployment. This is particularly relevant for EU AI Act.	What validation metrics are used? How validation is carried out (e.g., training-test splitting)? What are the metrics for reliability, safety and fairness? Which tools/techniques are employed for this? Relevant docs: project plans, Operation procedures-Documentation	
A.6.2.5	**AI system deployment** Not only development and validation, but also the plan to deploy should be documented.	Once requirements and specification are defined, how do you make sure to deploy the AI system with said requirements and speifications? E.g., project plans setting reliability or other metrics thresholds. Relevant docs: project plans	
A.6.2.6	**AI system operation and monitoring** As any complex system, the standard operating procedures and monitoring efforts for the AI system should be well documented. For instance, how well the AI system works (as expected?) or how it is maintained (when do we intervene?).	How are AI systems operated operation and monitored, including performance monitoring, repairs, updates, and user support? E.g., accuracy monitoring, error logs, incident repair process, update procedure, helpdesk contact channel How do you monitor if the AI system continues to perform as intended in production, including drift, unexpected use, and AI-specific security threats? E.g., drift detection, retraining trigger, misuse review, monitoring for model stealing or data poisoning, if any Relevant docs: project plans, Objectives-Monitoring-overview	
A.6.2.7	**AI system technical documentation** The documentation should not be one-sided, but – if relevant – the appropriate information should be available and understandable for various relevant parties, like developers, users and even regulators.	How do you make sure the right people get the right information? E.g., user instructions, intended purpose, technical limits, monitoring features, documentation for regulators or partners. How do you keep the AI system documentation complete and up to date during operation? E.g., architecture docs, data and validation records, update history, failure handling plans, roles and responsibilities.	

		Relevant docs: Stakeholder-Communication, Operating procedures-Documentation	
A.6.2.8	**AI system recording of event logs** As any complex and consequential systems, ScaleHigh must keep logs of AI system activity and errors.	At what stages of the AI system lifecycle do you enable event logging? Is logging enabled when the system is in use? E.g., logging during testing, deployment, operation, or maintenance. What kind of AI system events are logged? Are there any retention requirements? E.g., timestamps, input data, outputs outside normal ranges, system usage, retention period. Relevant docs: Operating procedures, Monitoring	

A.7 Data for AI systems

This section is about data governance whereby all data related to training, validating and testing and appropriate management practices must be defined and documented. Relevant AI Act articles are art. 10 (data governance), art. 11 and Annex IV (technical documentation) and art. 15 (accuracy, robustness and cybersecurity).

	Criterion	Observed in audit	Findings
A.7.2	**Data for development and enhancement of AI system** Data governance is fundamental for AI systems. Therefore, ScaleHigh must have a data management system in place.	How do you manage data used to develop or improve AI systems? Your overall data governance effort: e.g., data collection rules, access controls, dataset approval, labelling process, How do you make sure development data is appropriate, secure, and suitable for the intended use of the AI system? E.g., data provenance, representativeness, accuracy checks, privacy safeguards, integrity controls, if any Relevant docs: Operating procedures-Documentation	
A.7.3	**Acquisition of data** Among the data governance practices, how data is obtained and selected must be documented.	How do you decide what data to acquire and use for the AI system? E.g., data categories, amount of data, internal or external sources, open or synthetic data. What do you document about the data you acquire for AI development? E.g., provenance, demographics, prior handling, labelling details, privacy or copyright restrictions Relevant docs: Operating procedures-Documentation	

A.7.4	**Quality of data for AI systems** It is difficult to measure and validate Ai systems without a way to know how good is the used data. Therefore, ScaleHigh must also ensure the requirements for data quality.	What data quality requirements do you set for data? E.g., completeness, accuracy, consistency, representativeness, labelling quality. How do you check that training, validation, test, and production data meet your quality requirements? E.g., bias review, fairness adjustments, data cleaning, validation criteria. Similar to A.6.2.2 and A.6.2.5. Relevant docs: Operating procedures-Documentation	
A.7.5	**Data provenance** Similarly, to data sourcing and selection, data provenance should be recorded as part of the general data governance efforts.	How do you record where data used in the AI system comes from and how it has changed over time? E.g., source records, updates, labelling history, transformations, data transfers, ownership records, sharing history, if any Relevant docs: Operating procedures-Documentation	
A.7.6	**Data preparation** Before using the data, it must be prepared appropriately to be used. Therefore, ScaleHigh must document what are the data preparation steps.	What are and how do you decide which data preparation methods to use for a given AI task/dataset? E.g., selection criteria, statistical exploration, handling missing values, transformations used cleaning, normalization, scaling, encoding, imputation Relevant docs: Operating procedures-Documentation	

A.8 Information for interested parties of AI systems

This section is about communication on risks and impacts with users, customers and authorities. Relevant AI Act articles are art. 13 and art. 26 (transparency), and partially art. 27 (impact assessment) and art. 50 (transparency for GenAI).

	Criterion	Observed in audit	Findings
A.8.2	**System documentation and information for users** ScaleHigh must provide AI system users with the information they need.	What do you communicate to the users of the AI system? E.g., instructions, notifications they are interacting with AI, images are generated, purpose of the system, information on performance Relevant docs: Stakeholders-Communication	
A.8.3	**External reporting** ScaleHigh must provide a way for interested parties to alert the company of any negative impacts of the AI system.	Do you have a way for users to communicate with you on problems they may experience as a consequence of the system use? E.g., incidents, data	

		breaches, leaks, authorities concerned Relevant docs: Incident reporting procedures, law overview	
A.8.4	**Communication of incidents** ScaleHigh must properly prepare for reporting incidents to their users.	Do you have an incident notification procedure documented? Relevant docs: Operational procedures (Incident response procedures)	
A.8.5	**Information for interested parties** ScaleHigh must be ready and know what are the obligations for reporting to authorities or regulators about the Ai system. This is particularly relevant for EU AI Act.	What kind of documentation have you reported to the regulators (in EU)? Relevant docs: Overview of regulation, Operational procedures, FRIA	

A.9 Use of AI systems

This section is about how the organization defines and enforces the (internal) use and/or development of Ai systems. The relevant articles from the Ai Act are:

	Criterion	Observed in audit	Findings
A.9.2	**Processes for responsible use of AI systems** There should be standard operating procedures for using responsibly the AI system.	Do you have a list or policy on authorized AI tools? Relevant docs: Operating procedures, AI policy	
A.9.3	**Objectives for responsible use of AI system** The responsible AI objectives identified previously should be documented when the AI system is used.	Which are your responsible AI objectives? E.g., safety, reliability, explainability, fairness, security, etc. At what stage of the use/development of the AI system do you implement human oversight? E.g., performance monitoring, output monitoring, human-in-the-loop for automated decision making Relevant docs: Objectives-monitoring, Operational procedures, AI Impact assessment	
A.9.4	**Intended use of the AI system** ScaleHigh must ensure that the AI system is used as intended and in line with documentation.	Can you show how the AI operations respect the AI policy and/or guidelines? E.g., event logs, scheduled reviews of objectives Relevant docs: Operating procedures, AI policy	

A.10 Third-party and customer relationships

This section is about the responsibilities and accountability for use and/or development of AI systems being shared with third parties, like suppliers and customers. Relevant AI Act articles are Art. 26 (use according to instructions, oversight, relevant input data, monitoring and log retention) and Art. 13 (instructions for use and intended purpose).

	Criterion	Observed in audit	Findings
A.10.2	**Allocating responsibilities** There could be varying responsibilities shared between ScaleHigh, customers/users and third parties (like regulators). Therefore, these responsibilities should be properly allocated.	Can you show your suppliers register? In case of PII, what DPAs do you have in place for sharing personal data? As a AI system provider, what documentation do you provide to your customers? Relevant docs: Supplier register, DPAs	
A.10.3	**Suppliers** The organization shall establish a process to ensure that its usage of services, products or materials provided by suppliers aligns with the organization's approach to the responsible development and use of AI systems. ScaleHigh must have a way to keep track of the suppliers relevant for the AI system. The relationships with suppliers should not damage the responsible use and development objectives at ScaleHigh.	What documentation do your suppliers provide together with the AI system? What are your requirements for the suppliers? Is the documentation sufficient to pursue your responsible AI objectives? When have you scheduled the supplier reviews? Relevant docs: Supplier register	
A.10.4	**Customers** Not only suppliers, but also customers' expectations should be factored in for the ScaleHigh's approach to responsible AI.	What are the expectations of your customers? E.g., requirements, contractual agreements What and how do you communicate with customers? E.g., responsibilities, documentation, instructions Relevant docs: Stakeholders-Context	